

A12. Pràctica: Vulnerabilitats i escaneig de xarxa amb Nmap

0226. Seguretat informàtica

GRUP: SMX2C

RA3. Implanta mecanismes de seguretat activa aplicant tècniques i procediments per evitar accions malicioses, descrivint vulnerabilitats i avaluant els riscos associats.

NOM I COGNOMS: Posa el teu nom i cognoms.

DATA: Escribeu la data.

Enunciat de l'activitat:

Aquesta activitat es cenyeix a l'apartat NF3-AA2 (Vulnerabilitats) del RA3: amenaces, vulnerabilitats, CVE, risc, i eines de detecció (escàners de xarxa, IDS/IPS). La part pràctica fa servir Nmap, una eina real i legítima quan s'utilitza sobre sistemes propis o amb autorització expressa.

IMPORTANT — ús ètic: Nmap només s'ha d'utilitzar sobre equips propis, de l'aula, o amb autorització explícita per escrit del propietari. Escanejar xarxes alienes sense permís pot constituir un delicte (accés no autoritzat a sistemes informàtics).

Enunciat exercici 1

Explica la diferència entre amenaça, vulnerabilitat i risc, amb un exemple propi (inventat) per a cadascun dels tres conceptes, relacionat amb un ordinador de l'aula d'informàtica.

Enunciat exercici 2

Entra a la web cve.mitre.org o a nvd.nist.gov i cerca una CVE publicada en els últims 12 mesos que afecti un programa que coneguis (navegador, sistema operatiu, aplicació...). Indica: a) el codi CVE-AAAA-NNNNN; b) la puntuació CVSS i la gravetat; c) un resum en les teves paraules de en què consisteix la vulnerabilitat.

Enunciat exercici 3

Aplica la fórmula $\text{Risc} = \text{Probabilitat} \times \text{Impacte}$ a aquest escenari: un servidor de fitxers amb dades de nòmines es troba en una sala amb pany electrònic, però la contrasenya de l'aplicació de nòmines és "1234" i la coneixen tots els treballadors. a) Valora l'impacte (baix/mitjà/alt) i justifica-ho. b) Valora la probabilitat (baix/mitjà/alt) i justifica-ho. c) Proposa UNA mesura concreta que redueixi el risc sense haver de canviar la ubicació física del servidor.

Enunciat exercici 4

Instal·la Nmap al teu equip (o màquina virtual Linux/Windows) amb `apt install nmap` (Linux) o des de nmap.org (Windows). Executa un escaneig dels 20 ports més habituals sobre el teu propi equip (localhost/127.0.0.1) amb l'ordre: `nmap --top-ports 20 -sV -Pn 127.0.0.1`

```
Terminal - nmap

$ nmap --top-ports 20 -sV -Pn 127.0.0.1
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-09-08 20:15 UTC
Nmap scan report for localhost (127.0.0.1)
Host is up (0.0000050s latency).

PORT      STATE SERVICE      VERSION
21/tcp    closed ftp
22/tcp    closed ssh
23/tcp    closed telnet
25/tcp    closed smtp
53/tcp    closed domain
80/tcp    closed http
110/tcp   closed pop3
111/tcp   closed rpcbind
135/tcp   closed msrpc
139/tcp   closed netbios-ssn
143/tcp   closed imap
443/tcp   closed https
445/tcp   closed microsoft-ds
993/tcp   closed imaps
995/tcp   closed pop3s
1723/tcp  closed pptp
3306/tcp  closed mysql
3389/tcp  closed ms-wbt-server
5900/tcp  closed vnc
8080/tcp  closed http-proxy

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.28 seconds

$ nmap -sn 127.0.0.1/30
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-09-08 20:15 UTC
Nmap scan report for 127.0.0.0
Host is up.
Nmap scan report for localhost (127.0.0.1)
Host is up.
Nmap scan report for 127.0.0.2
Host is up.
Nmap scan report for 127.0.0.3
Host is up.
Nmap done: 4 IP addresses (4 hosts up) scanned in 0.00 seconds
```

Captura real: escaneig dels 20 ports més habituals fet expressament per a aquesta guia sobre un servidor de proves. Tots els serveis (FTP, SSH, HTTP, RDP, VNC, MySQL...) apareixen com a "closed": és el resultat esperat en un sistema net, sense serveis exposats innecessàriament.

Fes el mateix escaneig sobre EL TEU equip i adjunta la teva pròpia captura [CAPTURA]. Respon: a) Quants ports apareixen com "open" al teu equip? b) Si n'hi ha algun, a quin servei correspon i és realment necessari que estigui actiu? c) Per què és una bona pràctica de seguretat minimitzar el nombre de ports oberts ("superfície d'atac")?

Enunciat exercici 5

Executa ara un escaneig de descobriment d'amfitrions ("host discovery") sobre la teva pròpia xarxa local amb l'ordre: `nmap -sn 192.168.1.0/24` (adapta el rang a la teva xarxa real, consultant primer la teva pròpia IP amb `ipconfig/ifconfig`). [CAPTURA]

```
Terminal - nmap

$ nmap --top-ports 20 -sV -Pn 127.0.0.1
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-09-08 20:15 UTC
Nmap scan report for localhost (127.0.0.1)
Host is up (0.0000050s latency).

PORT      STATE SERVICE      VERSION
21/tcp    closed ftp
22/tcp    closed ssh
23/tcp    closed telnet
25/tcp    closed smtp
53/tcp    closed domain
80/tcp    closed http
110/tcp   closed pop3
111/tcp   closed rpcbind
135/tcp   closed msrpc
139/tcp   closed netbios-ssn
143/tcp   closed imap
443/tcp   closed https
445/tcp   closed microsoft-ds
993/tcp   closed imaps
995/tcp   closed pop3s
1723/tcp  closed pptp
3306/tcp  closed mysql
3389/tcp  closed ms-wbt-server
5900/tcp  closed vnc
8080/tcp  closed http-proxy

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.28 seconds

$ nmap -sn 127.0.0.1/30
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-09-08 20:15 UTC
Nmap scan report for 127.0.0.0
Host is up.
Nmap scan report for localhost (127.0.0.1)
Host is up.
Nmap scan report for 127.0.0.2
Host is up.
Nmap scan report for 127.0.0.3
Host is up.
Nmap done: 4 IP addresses (4 hosts up) scanned in 0.00 seconds
```

Captura real de referència (escaneig -sn sobre una xarxa de proves de només 4 adreces): mostra quins amfitrions estan actius sense escanejar-ne els ports.

Respon: a) Quants dispositius actius has trobat a la teva xarxa? b) Per què aquesta tècnica és útil per fer un INVENTARI de xarxa (relaciona-ho amb el que ja vas veure al mòdul de Xarxes Locals)? c) Per què, en un context de pentesting, sovint es prefereix fer aquest descobriment en mode passiu enlloc d'enviar paquets actius?

Enunciat exercici 6

Una petita empresa (una gestoria) et contracta com a tècnic per fer una primera auditoria de seguretat bàsica dels seus 8 ordinadors i el seu servidor. Elabora un pla d'actuació que inclogui: 1) quines eines utilitzaries per detectar vulnerabilitats (escàners, CVE, etc.); 2) com prioritzaries les vulnerabilitats trobades (fórmula de risc); 3) quina eina de detecció d'intrusions (IDS/IPS o honeypot) recomanaries per al servidor, i per què; 4) un breu apartat sobre la importància de revisar els logs periòdicament, encara que no s'hagi detectat cap incident.

Fonts: *Repositori "Materials" (GitHub, SMX-0226SI), NF3/AA2-vulnerabilitats.md (CC-BY-SA-4.0); CVE-Mitre (cve.mitre.org); INCIBE-CERT; Nmap (nmap.org).*